

fusiondataco.com

<https://fusiondataco.com>**58**

/ 100 Needs work

Pro | \$499 | Order pa_6nb0w01hmu1ca17f

Paid 2026-09-14 14:29 UTC | Audited 2026-09-14 14:29 UTC

8 pages scanned | 35 check groups | 36 passed

Findings: 5 (1 critical, 0 high, 2 medium, 2 low)

Audited 8 pages on fusiondataco.com: 5 issues (1 critical/high).

What this audit covers

Everything in Deep Audit, plus credentialed testing with a test login you provide (two-identity IDOR and privilege checks), one re-audit after you ship the fixes, and a 30 minute call to walk the findings.

Single Run: a site-wide, URL-only audit (up to 8 pages) covering security headers, cookies, CORS, exposed files, accessibility basics, broken links, mixed content, SEO/launch blockers, error-page leaks, TLS, email DNS and Core Web Vitals. The hosted deep audit adds a real browser: broken access control, admin/RBAC, write-authz and authenticated flows.

Pages audited: <https://fusiondataco.com/> <https://fusiondataco.com/pricing>
<https://fusiondataco.com/portfolio> <https://fusiondataco.com/products>
<https://fusiondataco.com/case-studies> <https://fusiondataco.com/about> <https://fusiondataco.com/blog>
<https://fusiondataco.com/founders>

Findings, worst first (5)

Severity	Category	What we found, and why it costs you
CRITICAL	Launch	robots.txt blocks the whole site User-agent: * / Disallow: / tells every search engine to stay out. Fine for staging, fatal for launch.
MEDIUM	Access control	Admin surface reachable without auth: /admin, /dashboard, /administrator /admin served a 200 client shell (HTTP can't prove the client gate; verify the API); /dashboard served a 200 client shell (HTTP can't prove the client gate; verify the API); /administrator served a 200 client shell (HTTP can't prove the client gate; verify the API).
MEDIUM	Errors	Soft 404 Unknown URLs return 200 instead of 404 — search engines index junk pages and monitoring never sees the breakage.
LOW	Auth hardening	Verify rate limiting on the login endpoint This app exposes a login / auth endpoint. We do not brute-force it, so we cannot confirm a limit exists — but AI builders almost never add one, and an unthrottled login invites credential-stuffing.
LOW	Content	Placeholder copy still on the page: your company The live page still shows scaffold text (your company). It reads as unfinished and can leak straight into search results and link previews.

Paste-ready fixes

Each block below is written for a coding agent (Claude Code, Cursor, Codex). Paste it as-is; it names the file, the change and how to verify it.

1. robots.txt blocks the whole site

CRITICAL | Launch

Address "robots.txt blocks the whole site": User-agent: * / Disallow: / tells every search engine to stay out. Fine for staging, fatal for launch.

2. Admin surface reachable without auth: /admin, /dashboard, /administrator

MEDIUM | Access control

Add a SERVER-SIDE authorization check to these routes/APIs (/admin, /dashboard, /administrator). In the route handler or shared middleware, reject anonymous or non-admin requests with 401/403 BEFORE returning anything – hiding the link in the UI is not a control. For Next.js, guard in middleware.ts and re-check the role inside each /api/admin handler. Verify an unauthenticated curl to each path returns 401/403. Standard: OWASP WSTG-ATHZ / CWE-306.

3. Soft 404

MEDIUM | Errors

Address "Soft 404": Unknown URLs return 200 instead of 404 – search engines index junk pages and monitoring never sees the breakage.

4. Verify rate limiting on the login endpoint

LOW | Auth hardening

Add rate limiting to your login and password-reset endpoints (report-only finding – verify this yourself). Limit attempts per IP and per account (e.g. 5 per 15 minutes) and add exponential backoff or a captcha after repeated failures. On Vercel use @upstash/ratelimit; on Supabase Auth enable the built-in rate limits. Standard: OWASP WSTG-ATHN / API4:2023.

5. Placeholder copy still on the page: your company

LOW | Content

Replace the placeholder copy (your company) with real content. Search the codebase for each phrase and write the actual headline/body/contact details. Standard: launch content hygiene.

What happens next

The automated report lands on this page and in your inbox now. Within one business day we email you from rob@fusiondataco.com to collect a test login and confirm scope; the credentialed deep audit follows within three business days, and the re-audit is yours whenever the fixes are live.

Where this report lives

Order page (re-renders the report any time):

http://127.0.0.1:3003/order/success?session_id=cs_test_rehearsal_mu1ca168

This PDF:

http://127.0.0.1:3003/api/order-report?session_id=cs_test_rehearsal_mu1ca168

Prepared for rob@fusiondataco.com by Fusion Data Company. Questions: rob@fusiondataco.com. Refund policy:

<https://80-20.dev/refunds>